



Regulatory & Compliance Requirements

HER/EMR Product to U.S. Clinics and Hospitals

Prepared as a planning reference.

1. Overview

This document consolidates the registrations, certifications, and compliance obligations that typically apply to a software company selling an Electronic Health Record (EHR) product to clinics or hospitals in the United States. Requirements are grouped by category and flagged by priority: Must-Have items are usually required before a credible first sale, Strongly Expected items are not always legally mandatory but are routinely demanded by hospital procurement and security review processes, and Conditional items apply only if specific features or use cases are present (e.g., e-prescribing, behavioral health data).

2. Core Certifications & Registrations

Requirement	What It Covers	Priority	Governing Body
ONC Health IT Certification	Certification under 45 CFR Part 170 via an ONC-Authorized Testing Lab and Certification Body. Required for clinics to use your EHR toward Medicare/Medicaid Promoting Interoperability incentives.	Must-Have	ONC / ONC-ACB
HIPAA Compliance Program	Documented security program: risk assessments, encryption, audit logging, breach response. Business Associate Agreements (BAAs) signed with every client.	Must-Have	HHS / OCR
HITECH Breach Notification	Separate breach notification timelines and duties layered on top of base HIPAA requirements.	Must-Have	HHS / OCR
Business Registration	Incorporation, foreign qualification in each state of operation, EIN.	Must-Have	State Secretaries of State / IRS
FDA Device Regulation	Generally excluded for standard EHR software under the 21st Century Cures Act. Applies only if clinical decision support features cross into diagnostic/treatment recommendations.	Conditional	FDA

3. Interoperability Requirements

Requirement	What It Covers	Priority	Governing Body
HL7 FHIR API Support	Standards-based data exchange API, required under §170.315(g)(10) of the 2015 Edition Cures Update if ONC-certified.	Must-Have	ONC
USCDI Compliance	Data model must support the United States Core Data for Interoperability standard.	Must-Have	ONC
Information Blocking Rules	Cures Act prohibition on unreasonably restricting access, exchange, or use of electronic health information. Affects contract terms and technical design.	Must-Have	ONC / HHS
HIPAA Transactions & Code Sets	X12, ICD-10, CPT standards if the EHR generates claims or interfaces with billing systems.	Conditional	HHS

4. Security & Privacy (Beyond Base HIPAA)

Requirement	What It Covers	Priority	Governing Body
42 CFR Part 2	Stricter consent rules than standard HIPAA, applies if any client treats substance use disorder patients.	Conditional	SAMHSA
State Privacy Laws	E.g. California CMIA, Texas Medical Records Privacy Act. Can be stricter than HIPAA and apply based on patient location, not company location.	Must-Have	State AGs
State Breach Notification Laws	Vary by state; often shorter notification windows than federal HITECH requirements.	Must-Have	State AGs
Subprocessor BAAs	Data Processing Agreements and BAAs with cloud hosting, AI vendors, and other subprocessors handling PHI.	Must-Have	Contractual

5. Conditional: E-Prescribing

Requirement	What It Covers	Priority	Governing Body
EPCS Compliance	Electronic Prescriptions for Controlled Substances. Requires third-party audit before enabling controlled substance e-prescribing.	Conditional	DEA, 21 CFR Part 1311
State E-Prescribing Rules	Some states impose additional licensing or certification requirements for e-prescribing platforms.	Conditional	State Boards of Pharmacy

6. Procurement-Driven (Not Legally Mandated, Commonly Required)

Requirement	What It Covers	Priority	Governing Body
SOC 2 Type II	Independent audit of security controls; frequently required by hospital vendor security review before contract signature.	Strongly Expected	AICPA-aligned auditors
HITRUST CSF Certification	Quasi-standard in enterprise health IT procurement; sometimes required instead of or alongside SOC 2, especially by hospitals.	Strongly Expected	HITRUST Alliance
E&O / Cyber Liability Insurance	Errors & omissions and cyber liability coverage, typically requested in hospital procurement and vendor contracts.	Strongly Expected	Insurance carriers

7. Suggested Sequencing

Phase 1 — Before First Sale

- Business registration, EIN, and state qualification.
- HIPAA compliance program and BAA template in place.
- ONC Health IT Certification process initiated (this is typically the longest lead-time item).



- FHIR API and USCDI data model support built in from the start.

Phase 2 — During Early Sales Cycles

- SOC 2 Type II audit (or HITRUST, depending on target customer expectations).
- Cyber liability and E&O insurance.
- Sub processor BAAs and data processing agreements finalized.

Phase 3 — As Feature Set Expands

- EPCS compliance if adding controlled substance e-prescribing.
- 42 CFR Part 2 controls if serving behavioral health or SUD treatment clients.
- Additional state-specific privacy or licensing requirements as you expand to new states.

8. Disclaimer

This document is a planning reference only and does not constitute legal advice. Health IT regulation changes frequently and requirements can vary by state, by customer type, and by the specific features your product offers. Engage healthcare regulatory counsel and a qualified ONC-Authorized Testing Lab before making compliance commitments to customers.

